

Нефункциональные требования (NFR) ЦП РСФСР

Документ детализирует требования к производительности, надёжности, информационной безопасности, наблюдаемости и эксплуатации платформы.

1. Производительность

Показатель	Целевое значение	Метод измерения
Пиковая нагрузка ввода	5 000 RPS на API-шлюзе	Нагрузочное тестирование (JMeter / Yandex Tank)
Среднее время отклика бизнес-API	≤ 200 мс (P95)	Prometheus / OpenTelemetry
Время отклика «тяжёлых» операций (выпуск ЦФА)	≤ 30 сек E2E	Synthetic monitoring
Время первого экрана мобильного приложения	$\leq 1,5$ сек на 4G	Real User Monitoring
TPS DLT-реестра	≥ 200 транзакций/сек	Профилирование DLT-узла
Concurrent users	$\geq 50\,000$ одновременно	Stress-тестирование

2. Надёжность и доступность

Показатель	Целевое значение
SLA годовой	99,99% (≤ 52 мин downtime/год)
MTTR (среднее время восстановления)	≤ 15 мин для критичных контуров
MTBF (среднее время между отказами)	$\geq 8\,760$ ч для критичных компонентов
RPO (точка восстановления)	0 для DLT-реестра и ЦФА-данных; ≤ 5 мин для прочих
RTO (время восстановления)	≤ 5 мин для критичных, ≤ 30 мин для прочих
Геораспределение	3 active-active ЦОД
Резервирование БД	Синхронная репликация $\geq N+2$
Backup	Ежечасные incremental + ежесуточные full, хранение 7 лет

3. Масштабируемость

- Горизонтальное масштабирование** всех stateless-сервисов через Kubernetes HPA.
- Вертикальное масштабирование** stateful-компонентов (БД) — до 1 ПБ хранилища на кластер.
- Sharding** ЦФА-реестра по идентификатору залогодателя для крупного объёма.

4. **Партнёрская модель распределения** для нагрузки оценочных и страховых модулей.

4. Информационная безопасность

4.1. Уровень защиты

Платформа соответствует **4-му (максимальному) уровню защиты по ГОСТ Р 57580.1** и реализует все 8 направлений защиты: - ОЗД — обеспечение защиты данных; - ОПИ — обеспечение защиты периметра ИС; - РСИ — разграничение и контроль доступа; - МАУ — мониторинг, аудит, реагирование; - ОПТ — обеспечение продолжительной защиты; - УПИ — управление инцидентами; - ОЗУ — обеспечение защиты учётных данных; - РЦК — реагирование на компьютерные атаки.

4.2. Криптография

- Только сертифицированные средства: КриптоПро CSP 5.0, ВипНет CSP, КриптоПро HSM.
- Алгоритмы: ГОСТ Р 34.10-2012 (ЭП), ГОСТ Р 34.11-2012 (хеш), ГОСТ Р 34.12-2015 / 34.13-2015 (шифрование).
- TLS-каналы — с использованием ГОСТ-сертификатов (КриптоПро TLS).

4.3. Защита персональных данных

- Соответствие 152-ФЗ и приказу ФСТЭК №21.
- Уровень защищённости ИСПДн — **УЗ-1** (по ПП РФ №1119).
- Регистрация в реестре операторов ПДн Роскомнадзора.
- Все операции с ПДн журналируются в неизменяемом audit log.

4.4. Защита КИИ

- Категория значимости — **1-я (наивысшая)** (ФЗ-187).
- Подключение к ГосСОПКА.
- Соответствие приказу ФСТЭК №239.
- Постоянное взаимодействие с НКЦКИ.

5. Наблюдаемость (Observability)

5.1. Метрики

- Бизнес-метрики: количество выпущенных ЦФА, объём эмиссии, время выпуска, конверсия.
- Технические метрики: RPS, latency, error rate, насыщенность ресурсов.
- Метрики ИБ: количество инцидентов, заблокированные запросы, неудачные авторизации.
- Хранение метрик — 13 месяцев в VictoriaMetrics с агрегацией по периодам.

5.2. Логи

- Структурированные JSON-логи всех сервисов.

- Централизованный сбор в Loki / отечественный аналог.
- Корреляция через trace_id.
- Хранение операционных логов — 13 месяцев.
- Хранение audit-логов — 10 лет (соответствует требованиям 152-ФЗ и НК РФ).

5.3. Трассировка

- OpenTelemetry-стек по всем сервисам.
- Сэмплинг 10% для штатных запросов, 100% для критичных контуров (выпуск, мена ЦФА).
- Хранение трасс — 30 дней (HOT), 180 дней (COLD).

5.4. Алертинг

- Двухуровневая система: автоматические алерты + дежурная смена SOC.
- Эскалация: L1 (1 мин) → L2 (5 мин) → L3 (15 мин) → руководство ОО (30 мин).

6. Эксплуатация

6.1. CI/CD

- Git-репозиторий — отечественный GitFlic / GitVerse / собственный GitLab on-prem.
- CI: pipelines с обязательными шагами:
 1. Static code analysis (PT Application Inspector, PVS-Studio).
 2. SAST / DAST (PT AppSec).
 3. Composition analysis (выявление уязвимых библиотек).
 4. Unit-тесты (покрытие ≥ 80%).
 5. Integration-тесты.
 6. Performance smoke-тесты.
 7. Подпись релизной сборки УКЭП.
- CD: GitOps (Argo CD / отечественный аналог), полная автоматизация деплоев, с механизмом канареечного развёртывания.

6.2. Управление конфигурацией

- Все конфигурации — в Git (Infrastructure as Code, Configuration as Code).
- Секреты — через HashiCorp Vault (или отечественный аналог) с шифрованием на HSM.

6.3. Backup и DR

- Полное тестирование DR-сценариев — ежеквартально.
- Recovery drill — раз в полугодие с участием SOC.

7. Совместимость и стандартизация

- API: REST (OpenAPI 3.1) для внешних интеграций; gRPC между внутренними сервисами.
- Документация API — автоматическая генерация в Swagger-стиле.

- Поддержка стандартов: OAuth 2.1, OpenID Connect, mTLS, JWT с RS256/GostR3410.
- Соответствие ISO/IEC 25010 (атрибуты качества ПО).

8. Требования к командам и эксплуатации

- 24×7 NOC (Network Operations Center).
- 24×7 SOC (Security Operations Center) с интеграцией в ГосСОПКА.
- Дежурные смены: ≥ 6 человек на смену для критичных контуров.
- Регулярные практики Red Team / Blue Team — каждые 6 месяцев.
- Ежегодный внешний пентест аккредитованной лабораторией ФСТЭК.

9. Требования к импортонезависимости

100% компонентов программно-аппаратной части должны: - быть включены в Единый реестр российского ПО (ПП РФ №1236), либо - быть сертифицированы ФСТЭК России / ФСБ России, либо - быть собственной разработкой оператора с открытым исходным кодом и сборкой на территории РФ.